

Application Security Audit Checklist for Open Hardware Projects with Internet Connectivity

Reference document and template pack for student research hardware projects

Version 1.1 — June 23, 2026

Scope and intended use

This document is a practical security-audit workflow for university research-group hardware projects that add internet, cloud, web, API, MQTT, wireless-gateway, or remote-control capability. It is not a substitute for institutional IT/security policy, laboratory safety review, IRB/privacy review, export-control review, or legal advice. It is intended to help students build secure practices into projects from the start.

June 2026 source review and update notes

This version updates the reference basis and GitHub packaging guidance after reviewing the current public guidance available as of June 23, 2026.

Material changes from Version 1.0:

- Updated web-application verification references to OWASP ASVS 5.0.0, while retaining OWASP ASVS as the primary checklist reference for student web/API components.
- Added OWASP Top 10 2025 as the current awareness reference for common web application risks.
- Added OWASP API Security Top 10 2023 and OWASP Web Security Testing Guide stable version as supporting references for API and test planning.
- Added OWASP Software Component Verification Standard (SCVS) as a supply-chain assurance reference.
- Added CISA 2025 Minimum Elements for a Software Bill of Materials as a draft/watch item, not a mandatory control, because it was published for public comment and may change before finalization.
- Added CISA Software Bill of Materials for AI - Minimum Elements as an optional reference for projects that incorporate AI/ML models, LLM services, AI-enabled perception, or AI-driven control logic.
- Added NIST SP 800-218 Rev. 1 / SSDF Version 1.2 Initial Public Draft as a watch item while retaining NIST SP 800-218 / SSDF Version 1.1 as the stable baseline.
- Added GitHub repository publication guidance, recommended repository structure, README, license recommendation, GitHub Pages notes, and a future update prompt.

Interpretation rule: use final stable standards as requirements. Treat draft/public-comment guidance as update-watch material unless your sponsor, collaborator, institutional IT office, or contract specifically requires it.

How to use this document

1. Complete the audit record and risk classification before implementation.
2. Review the stop-sign questions before any network connection.
3. Work through the checklist sections that apply to the project.
4. If a checklist item fails or is marked unknown, complete the indicated add-on and attach the evidence.
5. Use the template appendix or companion template pack to create reusable project files.
6. Re-run the checklist before public demo, field deployment, or open-source release.

Verifiable source basis

The checklist is synthesized from the following official or widely recognized sources. The mapping table below shows where each source most directly informs the workflow.

Area	Primary source references
IoT device security baseline	R1: OWASP Internet of Things Security Verification Standard (ISVS) ; R2: OWASP Internet of Things Security Testing Guide (ISTG) ; R5: NIST SP 800-213: IoT Device Cybersecurity Guidance ; R6: NISTIR 8259A: IoT Device Cybersecurity Capability Core Baseline ; R7: NISTIR 8259B: IoT Non-Technical Supporting Capability Core

Area	Primary source references
	Baseline
Secure development process	R8: NIST SP 800-218: Secure Software Development Framework (SSDF) Version 1.1 ; R37: NIST SP 800-218 Rev. 1 / SSDF Version 1.2 Initial Public Draft ; R11: CISA Secure by Design ; R30: OWASP Software Assurance Maturity Model (SAMM)
Web/API security	R3: OWASP Application Security Verification Standard (ASVS) ; R31: OWASP Top Ten Web Application Security Risks ; R32: OWASP API Security Top 10 ; R33: OWASP Web Security Testing Guide ; R4: OWASP Cheat Sheet Series ; R16: OWASP Zed Attack Proxy (ZAP)
Threat modeling	R15: OWASP Threat Dragon ; R1: OWASP ISVS ; R8: NIST SSDF Version 1.1
Secrets, repo hygiene, and GitHub controls	R17: GitHub: Adding a security policy to your repository ; R18: GitHub: Secret scanning push protection ; R19: GitHub: Dependabot alerts ; R20: GitHub: Code scanning with CodeQL
Software supply chain and SBOM	R21: OSV-Scanner ; R22: OWASP Dependency-Check ; R23: OWASP CycloneDX ; R24: OpenSSF Scorecard ; R25: SLSA ; R34: OWASP Software Component Verification Standard ; R35: CISA 2025 Minimum Elements for a Software Bill of Materials
AI-enabled hardware and AI services	R36: CISA Software Bill of Materials for AI - Minimum Elements ; R37: NIST SSDF Version 1.2 Initial Public Draft
TLS/network protocol configuration	R26: Mozilla SSL Configuration Generator ; R27: OASIS MQTT Version 5.0 Specification
Firmware hardening examples	R28: Espressif ESP-IDF Secure Boot documentation ; R29: Espressif ESP-IDF Flash Encryption documentation
Incident response and vulnerability disclosure	R12: CISA Vulnerability Disclosure Policy Template ; R13: CISA Known Exploited Vulnerabilities Catalog ; R14: CERT Guide to Coordinated Vulnerability Disclosure
Risk/privacy framing	R9: NIST Cybersecurity Framework 2.0 ; R10: NIST Privacy Framework
Repository publication and licensing	R38: GitHub: Creating a new repository ; R39: GitHub: Uploading a project to GitHub ; R40: GitHub Pages publishing source ; R41: Creative Commons Attribution 4.0 International

Review gates

- **Design review:** Before buying parts or selecting firmware/cloud stack.
- **Pre-network review:** Before connecting to Wi-Fi, Ethernet, cellular, Bluetooth gateway, LoRaWAN gateway, MQTT broker, HTTP API, cloud dashboard, university network, or public internet.
- **Pre-demo/release review:** Before public demo, conference demo, GitHub release, field test, collaborator deployment, or publication of deployment instructions.
- **Post-change review:** After adding remote control, OTA updates, new sensors, cloud logging, human data, authentication, AI/LLM integration, or a public web interface.

Stop-sign questions

If any answer is **Yes**, the project needs faculty/PI review before internet connection and should complete the indicated add-on.

Question	Required action
Can the device move, heat, actuate, pressurize, cut, shock, illuminate lasers, fly, pump fluid, or damage equipment?	A4 Command Authorization and Safety Interlocks; A7 Signed Firmware and Recovery.
Can a remote user change device behavior, not just view data?	A4 Command Authorization and Safety Interlocks; A11 Audit Logging.
Does the project collect human-subject, location, image, audio, biometric, health, student, or personally identifying data?	A9 Data Protection and Privacy.
Will code, firmware, CAD, PCB, deployment instructions, or datasets be public?	A13 Open-Source Release and Web Conversion.
Will the device be reachable from the public internet?	Prefer redesign. Otherwise A2 Network Isolation plus external security review.
Does the project use default passwords, shared passwords, hardcoded API keys, or unauthenticated MQTT/HTTP endpoints?	Do not connect. A3 Authentication and Device Identity; A6 Secrets Hygiene.
Is firmware update possible over the air or by end users?	A7 Signed Firmware and Recovery.
Would compromise embarrass the group, expose university systems, or harm a collaborator?	Treat as high-risk and require written threat model and PI sign-off.

Risk classification

Low risk: local-only or outbound-only display, no remote commands, no personal/sensitive data, no public internet exposure.

Medium risk: cloud logging, web dashboard, MQTT/HTTP/WebSocket API, remote configuration, public repository, or deployment instructions.

High risk: remote actuation, safety impact, human/identifiable data, public endpoint, OTA update, device-stored credentials, or deployment outside the lab.

Go/no-go rule

No identity, no encryption, no update path, no logs, no internet.

A project may connect to the internet only when: unique credentials exist; no secrets are committed; internet traffic is encrypted; unnecessary public inbound services are absent; remote commands are authenticated, authorized, logged, and safety-limited; dependencies are scanned; a basic threat model exists; and medium/high-risk projects have faculty/PI review.

Detailed audit checklist

3.1 Project intake and security ownership

Status	ID	Control and required evidence	If not passed or unknown
[]	PI-1	Project purpose, users, environment, and expected connectivity are documented. Evidence: One-paragraph project summary; intended users; lab/field/demo setting; connectivity modes.	A1 Threat Modeling; T1 Audit Record; sources R1, R5, R8
[]	PI-2	A data-flow diagram exists before implementation. Evidence: Diagram includes device, sensors, actuators, cloud service, API, app/dashboard, broker, database, users, external dependencies, and trust boundaries.	A1 Threat Modeling; T2 Threat Model; T3 Data Flow; resource R15
[]	PI-3	Assets and abuse cases are listed. Evidence: Assets include firmware, credentials, data, physical hardware, cloud accounts, source repo, logs, and university network access. Abuse cases include stolen device, malicious user, curious student, internet scanner, compromised laptop, malicious dependency.	A1 Threat Modeling; T4 Asset Inventory; sources R1, R6, R8
[]	PI-4	Security owner and escalation path are assigned. Evidence: Named student security owner, faculty/PI reviewer, and lab/IT escalation contact.	A12 Incident Response; T5 Security Ownership; sources R7, R8
[]	PI-5	Risk level is assigned and accepted. Evidence: Low/Medium/High classification using this document's rubric; high-risk items have written faculty sign-off.	T6 Risk Classification; sources R5, R9

3.2 Architecture and network exposure

Status	ID	Control and required evidence	If not passed or unknown
[]	NE-1	The default design uses outbound-only connectivity. Evidence: Device initiates encrypted outbound connection to broker/cloud/API; no public inbound management interface.	A2 Network Isolation; sources R1, R5, R6, R11
[]	NE-2	No unnecessary public services are exposed. Evidence: No public SSH, Telnet, VNC, Jupyter, Flask debug server, Node-RED admin, unauthenticated HTTP, or unauthenticated MQTT.	A2 Network Isolation; T7 Network Exposure Review; sources R1, R2, R6
[]	NE-3	Network placement is intentional. Evidence: Device is on guest/lab IoT network, isolated router, or segmented VLAN; not on general faculty/student/admin networks unless approved.	A2 Network Isolation; T7 Network Exposure Review; sources R5, R6
[]	NE-4	Firewall rules are minimal. Evidence: Only required outbound ports/destinations allowed; inbound rules are denied by default unless explicitly justified.	A2 Network Isolation; sources R9, R11
[]	NE-5	Network scan confirms expected exposure. Evidence: Nmap or comparable scan shows only expected ports before network connection/demo/release.	T7 Network Exposure Review; A2 Network Isolation; source R2
[]	NE-6	Local discovery and pairing are controlled. Evidence: mDNS, UPnP, Bluetooth pairing, Wi-Fi AP/captive portal, and ad hoc interfaces are disabled unless needed and documented.	A2 Network Isolation; A3 Identity; sources R1, R6

3.3 Authentication and device identity

Status	ID	Control and required evidence	If not passed or unknown
[]	AI-1	Every human user authenticates for non-public functions. Evidence: Dashboard, admin panel, API, broker, and database require login for data access, configuration, and commands.	A3 Authentication & Device Identity; sources R3, R4
[]	AI-2	No default, shared, or hardcoded passwords are used. Evidence: Each user/device has unique credentials or certificates; no lab-wide shared admin password.	A3 Authentication & Device Identity; sources R6, R11
[]	AI-3	Admin accounts use MFA where supported. Evidence: MFA enabled on GitHub, cloud console, database, broker, and deployment accounts.	A3 Authentication & Device Identity; sources R4, R11
[]	AI-4	Each device has a unique identity. Evidence: Per-device API token, client certificate, or similar identity; one compromised device can be revoked without replacing all devices.	A3 Authentication & Device Identity; T8 Device Registry; sources R1, R6
[]	AI-5	Tokens and certificates are least-privilege. Evidence: Device credential can only read/write necessary topics/endpoints and cannot administer the project.	A3 Authentication & Device Identity; sources R3, R4, R27
[]	AI-6	Credential revocation is tested. Evidence: Procedure exists to revoke one device/user and verify it can no longer connect.	A12 Incident Response; T8 Device Registry; sources R6, R7

3.4 Authorization, remote commands, and safety interlocks

Status	ID	Control and required evidence	If not passed or unknown
[]	AZ-1	Read and write permissions are separated. Evidence: Users/devices allowed to view data are not automatically allowed to send commands or change configuration.	A4 Command Authorization & Safety Interlocks; sources R3, R4
[]	AZ-2	Remote commands require explicit authorization. Evidence: Commands are limited by role, device ID, device state, safety limits, and intended operating mode.	A4 Command Authorization & Safety Interlocks; T10 Command Register; sources R1, R3
[]	AZ-3	Safety-relevant commands have interlocks. Evidence: Software and/or physical interlock prevents unsafe heat, motion, pressure, voltage, optical power, fluid flow, chemical exposure, or mechanical action.	A4 Safety Interlocks; T10 Command Register; sources R1, R5
[]	AZ-4	Command replay is prevented or bounded. Evidence: Protocol uses TLS session protection plus nonce, timestamp, broker session properties, sequence number, or idempotent command handling where appropriate.	A4 Command Authorization; sources R3, R27
[]	AZ-5	All remote commands are logged. Evidence: Logs include user/device identity, command, time, source, result, and safety-limit decision; logs do not include secrets.	A11 Audit Logging; sources R4

3.5 Transport security

Status	ID	Control and required evidence	If not passed or unknown
[]	TS-1	All internet traffic is encrypted in transit. Evidence: Use HTTPS, MQTTS, WSS, SSH, VPN, or equivalent; no plaintext HTTP/MQTT over untrusted networks.	A5 TLS/mTLS; sources R1, R3, R26, R27
[]	TS-2	Certificate validation is enabled. Evidence: No 'verify=False', no 'accept all certificates', no self-signed certificate accepted without pinning or trusted CA configuration.	A5 TLS/mTLS; sources R3, R4, R26
[]	TS-3	mTLS or per-device cryptographic identity is considered for medium/high-risk devices. Evidence: Decision documented; for high-risk deployments, mutual TLS or equivalent device-bound identity is preferred.	A5 TLS/mTLS; A3 Identity; sources R1, R6
[]	TS-4	No insecure protocol fallback exists. Evidence: No automatic fallback to HTTP, plaintext MQTT, older TLS settings, or debug endpoints.	A5 TLS/mTLS; sources R3, R26
[]	TS-5	Time synchronization supports TLS and audit logs. Evidence: Device has NTP, RTC, broker/cloud-provided time, or documented operating limits.	A5 TLS/mTLS; A11 Audit Logging; sources R6

3.6 Secrets management

Status	ID	Control and required evidence	If not passed or unknown
[]	SM-1	No secrets are committed to the repository. Evidence: Secret scan shows no API keys, Wi-Fi passwords, private keys, OAuth secrets, database URLs, or tokens in current files or history.	A6 Secrets Hygiene; T9 Secrets Inventory; sources R4, R18
[]	SM-2	Local secret files are ignored. Evidence: .gitignore covers .env, keys, certs, local configs, generated tokens, and deployment secrets.	A6 Secrets Hygiene; T14 .gitignore Starter; source R18
[]	SM-3	Secrets are injected during provisioning/deployment. Evidence: Environment variables, private config, secrets manager, or provisioning script used instead of public firmware/source.	A6 Secrets Hygiene; sources R4, R8
[]	SM-4	Logs and screenshots do not leak credentials. Evidence: Serial output, web logs, GitHub Actions logs, lab notebooks, tutorials, and public images are reviewed.	A6 Secrets Hygiene; A11 Audit Logging; sources R4, R18
[]	SM-5	Credential rotation is documented. Evidence: Procedure exists for leaked token/key/cert, including detection, revocation, replacement, and verification.	A12 Incident Response; T9 Secrets Inventory; sources R4, R13

3.7 Firmware and device hardening

Status	ID	Control and required evidence	If not passed or unknown
[]	FW-1	Firmware versions are traceable. Evidence: Binary artifact maps to source commit, build date, toolchain, board revision, and dependency versions.	A7 Signed Firmware & Recovery; T11 Firmware Release Record; sources R8, R25
[]	FW-2	Secure boot is used where available for field/high-risk devices. Evidence: Device verifies bootloader/application integrity before running; exceptions documented.	A7 Signed Firmware & Recovery; sources R1, R28
[]	FW-3	Flash/storage encryption is considered where secrets or sensitive data are stored. Evidence: Decision documented; enabled for high-risk physical access scenarios where supported.	A7 Signed Firmware & Recovery; A9 Data Protection; sources R1, R29
[]	FW-4	Debug interfaces are disabled or access-controlled before deployment. Evidence: JTAG/SWD/UART bootloader, debug web UI, REPL, and serial console are disabled or physically protected for field use.	A7 Device Hardening; sources R1, R2
[]	FW-5	Firmware update path is defined and tested. Evidence: Manual or OTA update process exists; update failure behavior is tested.	A7 Signed Firmware & Recovery; sources R1, R6
[]	FW-6	Firmware updates are signed for medium/high-risk or public projects. Evidence: Device accepts only signed firmware from trusted maintainers; signing keys are protected.	A7 Signed Firmware & Recovery; sources R1, R28
[]	FW-7	Malformed input does not crash or unlock unsafe behavior. Evidence: Basic fuzz/bad-input tests run against network messages, serial input, API payloads, and command parser.	A7 Robust Input Handling; A8 Web/API Security; sources R2, R3

3.8 Web application, API, dashboard, and mobile-app security

Status	ID	Control and required evidence	If not passed or unknown
[]	WA-1	ASVS target level is selected. Evidence: OWASP ASVS 5.0.0 Level 1 minimum for simple student web/API apps; Level 2 for remote control, human data, public deployment, or meaningful research data exposure.	A8 Web/API Security; sources R3, R31, R32, R33
[]	WA-2	Authentication protects non-public views and endpoints. Evidence: No unauthenticated admin, data, status, device registration, command, or configuration routes.	A8 Web/API Security; sources R3, R4, R31, R32, R33

Status	ID	Control and required evidence	If not passed or unknown
[]	WA-3	Access-control tests are written. Evidence: A normal user cannot access another user's project/device/admin action by changing URL, ID, topic, or parameter.	A8 Web/API Security; sources R3, R4, R31, R32, R33
[]	WA-4	Input validation rejects malformed or dangerous input. Evidence: API rejects unexpected types, long strings, malformed JSON, path traversal, command injection, and unsafe file upload.	A8 Web/API Security; sources R3, R4, R31, R32, R33
[]	WA-5	Browser security basics are configured. Evidence: CSRF protection for browser-session mutations; CORS not wide open for authenticated APIs; secure cookies; no debug mode in production.	A8 Web/API Security; sources R3, R4, R31, R32, R33
[]	WA-6	Rate limiting is applied to abuse-prone actions. Evidence: Login, command, data upload, registration, and expensive endpoints are rate-limited.	A8 Web/API Security; sources R3, R4, R31, R32, R33
[]	WA-7	A baseline dynamic scan is run before release. Evidence: OWASP ZAP baseline or comparable DAST scan has no unresolved high-risk findings.	A8 Web/API Security; sources R16, R33
[]	WA-8	Static/code scanning is enabled where practical. Evidence: CodeQL, Semgrep, language-specific linters, or CI tests run on pull requests for supported languages.	A8 Web/API Security; sources R20, R33

3.9 Data protection and privacy

Status	ID	Control and required evidence	If not passed or unknown
[]	DP-1	Data inventory exists. Evidence: Lists sensor data, command data, images/audio/video, location, user info, credentials, logs, metadata, and retention owner.	A9 Data Protection & Privacy; T12 Data Inventory; sources R5, R6, R10
[]	DP-2	Data minimization is applied. Evidence: Collect only what the project needs; reduce resolution/frequency/identifiability where possible.	A9 Data Protection & Privacy; sources R10, R11
[]	DP-3	Sensitive data is encrypted at rest. Evidence: Database, SD card, flash, laptop export, backups, and cloud buckets are encrypted or documented as non-sensitive.	A9 Data Protection & Privacy; sources R6, R10
[]	DP-4	Retention period is defined. Evidence: Logs/data have deletion period; demo data is cleaned after event unless retained for research record.	A9 Data Protection & Privacy; T12 Data Inventory; sources R7, R10
[]	DP-5	Human-subject or identifiable data triggers appropriate review. Evidence: IRB/privacy/data-use review considered for people, images, audio, biometrics, health, student records, or precise location.	A9 Data Protection & Privacy; sources R10
[]	DP-6	Demos use synthetic or sanitized data. Evidence: No real credentials, private images, internal IPs, personal data, or collaborator data in public demos, papers, slides, or GitHub repos.	A13 Open-Source Release; sources R11, R17

3.9A Optional AI/ML and AI-service security check

Use this section only if the project uses AI/ML models, LLM APIs, computer vision models, AI-generated control decisions, AI-assisted alerts, or AI-enabled user interfaces.

Status	ID	Control and required evidence	If not passed or unknown
[]	AI-1	AI component inventory exists. Evidence: list of models, APIs, datasets, prompts/system instructions, inference endpoints, and model/package versions.	A10 Dependency/SBOM; A9 Data Protection; sources R36, R37
[]	AI-2	AI is not the sole safety authority for physical actuation. Evidence: safety-critical commands pass deterministic authorization, range, and interlock checks independent of model output.	A4 Command Authorization; sources R1, R5, R11
[]	AI-3	Training, prompt, and inference data are reviewed for sensitive content. Evidence: no personal, confidential, or export-controlled data sent to external AI services unless approved.	A9 Data Protection & Privacy; sources R10, R36
[]	AI-4	Model/API failure behavior is safe. Evidence: timeouts, hallucinated commands, malformed outputs, service outages, and refusal/error responses default to safe device states.	A4 Command Authorization; A11 Logging; sources R5, R11
[]	AI-5	AI-related dependencies are scanned and documented. Evidence: model packages, Python/JS dependencies, containers, and hosted services are included in dependency review and SBOM notes.	A10 Dependency/SBOM; sources R34, R35, R36

3.10 Dependencies, supply chain, and open-source hygiene

Status	ID	Control and required evidence	If not passed or unknown
[]	SC-1	Dependencies are declared and locked. Evidence: requirements.txt/pyproject, package-lock, Cargo.lock, platformio.ini, west.yml, Dockerfile, or equivalent are present and reproducible.	A10 Dependency/SBOM; sources R8, R25
[]	SC-2	Dependency vulnerability scanning is enabled. Evidence: Dependabot, OSV-Scanner, OWASP Dependency-Check, or equivalent runs before release and ideally in CI.	A10 Dependency/SBOM; resources R19, R21, R22
[]	SC-3	High/critical findings are resolved or accepted. Evidence: Known exploited vulnerabilities are prioritized; residual risk is documented.	A10 Dependency/SBOM; A12 Incident Response; sources R13, R19, R21
[]	SC-4	SBOM is generated for public/field releases. Evidence: CycloneDX or SPDX SBOM attached to release or stored with project record. For 2026 updates, consider CISA draft fields such as component hash, license, tool name, and generation context where feasible.	A10 Dependency/SBOM; sources R23, R35
[]	SC-5	Open-source security posture is checked. Evidence: OpenSSF Scorecard run for public repos, especially before sharing project as reusable template.	A10 Dependency/SBOM; source R24
[]	SC-6	Repository protections are enabled. Evidence: Main branch protection, pull request review, CI checks, security policy, least-privilege GitHub Actions permissions where practical.	A13 Open-Source Release; sources R17, R24, R25

3.11 Logging, monitoring, and incident response

Status	ID	Control and required evidence	If not passed or unknown
[]	LM-1	Security events are logged. Evidence: Login failures, command attempts, device provisioning, firmware update, token errors, unexpected reboots, and rejected safety actions are logged.	A11 Audit Logging; sources R4, R6
[]	LM-2	Logs are useful but not dangerous. Evidence: Logs include timestamp, device ID, user ID, action, result, and source context; no passwords/tokens/private keys/personal data unless justified.	A11 Audit Logging; sources R4
[]	LM-3	Alerts exist for high-risk events. Evidence: Someone receives notification for repeated failed logins, command rejection, device compromise, update failure, unexpected public exposure, or leaked secret.	A11 Monitoring; A12 Incident Response; sources R9, R13
[]	LM-4	Incident response steps are documented. Evidence: Revoke token, disable device, rotate keys, preserve logs, notify PI/IT/collaborator, patch, redeploy, and write after-action notes.	A12 Incident Response; T13 Incident Response Plan; sources R12, R13, R14
[]	LM-5	Vulnerability disclosure path exists for public projects. Evidence: SECURITY.md gives reporting channel, scope, safe harbor language if appropriate, expected response, and supported versions.	A12 Vulnerability Disclosure; T15 SECURITY.md; sources R12, R14, R17

3.12 Pre-connection and pre-release testing

Status	ID	Control and required evidence	If not passed or unknown
[]	PR-1	Pre-network gate is passed before internet connection. Evidence: Threat model, secrets scan, network scan, TLS verification, unique credentials, and risk classification are complete.	T16 Release Signoff; sources R1, R5, R6, R8
[]	PR-2	Remote-control projects pass command/safety tests. Evidence: Authorization, safety interlocks, replay/bad-input behavior, and command logs are tested.	A4 Command Authorization; A11 Logging; sources R1, R2, R3
[]	PR-3	Web/API components pass baseline appsec checks. Evidence: Authentication, access-control tests, input validation tests, ZAP or comparable scan, and no debug mode.	A8 Web/API Security; sources R3, R16
[]	PR-4	Public releases are scrubbed. Evidence: No secrets, internal network details, private data, or unsafe default setup instructions; SECURITY.md and secure deployment guide included.	A13 Open-Source Release; sources R11, R17, R18
[]	PR-5	High-risk deployment has independent review. Evidence: Faculty/PI plus technically capable reviewer signs off; university IT/security review used where required.	T16 Release Signoff; sources R5, R8, R9

Security add-on catalog

A1. Threat Modeling

Use when: Use when the project has any network connectivity, cloud component, remote configuration, web dashboard, public repo, or safety impact.

Deliverables:

- Data-flow diagram with trust boundaries.
- Asset inventory and abuse cases.
- Top five threats with mitigations and residual risks.
- Faculty/PI sign-off for high-risk residual risks.

Resources: [R1: OWASP Internet of Things Security Verification Standard \(ISVS\)](#); [R5: NIST SP 800-213: IoT Device Cybersecurity Guidance](#); [R8: NIST SP 800-218: Secure Software Development Framework \(SSDF\)](#); [R15: OWASP Threat Dragon](#); [R30: OWASP Software Assurance Maturity Model \(SAMM\)](#)

Templates: T2 Threat Model; T3 Data Flow; T4 Asset Inventory; T6 Risk Classification

A2. Network Isolation

Use when: Use when a device connects to Wi-Fi/Ethernet/cellular or exposes any service.

Deliverables:

- Outbound-only architecture unless an exception is approved.
- IoT/guest/lab segment or isolated router.
- No public port forwarding; default-deny inbound rules.
- Network scan evidence before demo/release.

Resources: [R1: OWASP Internet of Things Security Verification Standard \(ISVS\)](#); [R2: OWASP Internet of Things Security Testing Guide \(ISTG\)](#); [R5: NIST SP 800-213: IoT Device Cybersecurity Guidance](#); [R6: NISTIR 8259A: IoT Device Cybersecurity Capability Core Baseline](#); [R11: CISA Secure by Design](#)

Templates: T7 Network Exposure Review

A3. Authentication and Device Identity

Use when: Use when humans, devices, brokers, APIs, cloud dashboards, or databases authenticate.

Deliverables:

- Unique human accounts and unique device identities.
- MFA for admin/cloud/GitHub accounts.
- Per-device token/certificate with least privilege.
- Revocation procedure tested.

Resources: [R3: OWASP Application Security Verification Standard \(ASVS\)](#); [R4: OWASP Cheat Sheet Series](#); [R6: NISTIR 8259A: IoT Device Cybersecurity Capability Core Baseline](#); [R11: CISA Secure by Design](#)

Templates: T8 Device Registry; T9 Secrets Inventory

A4. Command Authorization and Safety Interlocks

Use when: Use when a remote user or service can change device state, configuration, motion, heat, voltage, pressure, fluid, optics, or other physical behavior.

Deliverables:

- Command register with allowed roles and safety limits.
- Software or physical interlock design.
- Replay/bad-input test results.
- Command audit log sample.

Resources: [R1: OWASP Internet of Things Security Verification Standard \(ISVS\)](#); [R2: OWASP Internet of Things Security Testing Guide \(ISTG\)](#); [R3: OWASP Application Security Verification Standard \(ASVS\)](#); [R4: OWASP Cheat Sheet Series](#); [R27: OASIS MQTT Version 5.0 Specification](#)

Templates: T10 Command Register; T13 Incident Response Plan

A5. TLS/mTLS

Use when: Use when the project exchanges data, credentials, commands, logs, or firmware over a network.

Deliverables:

- TLS-enabled protocol only.
- Certificate validation enabled.
- No insecure fallback.
- mTLS/per-device cryptographic identity decision for medium/high risk.

Resources: [R1: OWASP Internet of Things Security Verification Standard \(ISVS\)](#); [R3: OWASP Application Security Verification Standard \(ASVS\)](#); [R26: Mozilla SSL Configuration Generator](#); [R27: OASIS MQTT Version 5.0 Specification](#)

Templates: T7 Network Exposure Review; T8 Device Registry

A6. Secrets Hygiene

Use when: Use for every project that touches credentials, Wi-Fi, API keys, certificates, tokens, GitHub Actions secrets, or database URLs.

Deliverables:

- Secret scan result.
- .gitignore and .env.example files.
- Secrets provisioned outside public repo/firmware.
- Rotation procedure and leaked-secret response.

Resources: [R4: OWASP Cheat Sheet Series](#); [R8: NIST SP 800-218: Secure Software Development Framework \(SSDF\)](#); [R18: GitHub: Secret scanning push protection](#)

Templates: T9 Secrets Inventory; T14 .gitignore Starter; T17 .env.example

A7. Signed Firmware and Recovery

Use when: Use when firmware is user-updatable, OTA-updatable, deployed outside the lab, stores secrets, or controls physical effects.

Deliverables:

- Version traceability from binary to source commit.
- Secure boot decision; enabled where appropriate.
- Flash/storage encryption decision.
- Signed update and rollback/recovery test.

Resources: [R1: OWASP Internet of Things Security Verification Standard \(ISVS\)](#); [R2: OWASP Internet of Things Security Testing Guide \(ISTG\)](#); [R6: NISTIR 8259A: IoT Device Cybersecurity Capability Core Baseline](#); [R8: NIST SP 800-218: Secure Software Development Framework \(SSDF\)](#); [R28: Espressif ESP-IDF Secure Boot documentation](#); [R29: Espressif ESP-IDF Flash Encryption documentation](#)

Templates: T11 Firmware Release Record

A8. Web/API Security

Use when: Use when the project has a dashboard, REST/GraphQL API, WebSocket service, MQTT bridge, cloud function, mobile app, or Jupyter-like interface.

Deliverables:

- ASVS target level.
- Authentication and access-control tests.
- Input validation and rate limiting.
- ZAP or comparable dynamic scan.
- Code scanning where supported.

Resources: [R3: OWASP Application Security Verification Standard \(ASVS\)](#); [R31: OWASP Top Ten Web Application Security Risks](#); [R32: OWASP API Security Top 10](#); [R33: OWASP Web Security Testing Guide](#); [R4: OWASP Cheat Sheet Series](#); [R16: OWASP Zed Attack Proxy \(ZAP\)](#); [R20: GitHub: About code scanning with CodeQL](#)

Templates: T18 API Endpoint Inventory; T16 Release Signoff

A9. Data Protection and Privacy

Use when: Use when any data is collected, stored, transmitted, displayed, logged, or published.

Deliverables:

- Data inventory and classification.
- Minimization and retention decisions.
- Encryption at rest decision.
- Human-subject/privacy review trigger check.

- Demo data scrub plan.

Resources: [R5: NIST SP 800-213: IoT Device Cybersecurity Guidance](#); [R6: NISTIR 8259A: IoT Device Cybersecurity Capability Core Baseline](#); [R10: NIST Privacy Framework](#); [R11: CISA Secure by Design](#)

Templates: T12 Data Inventory

A10. Dependency/SBOM

Use when: Use for every project with third-party packages, firmware libraries, container images, GitHub Actions, Python/Node/C/C++ dependencies, or public release.

Deliverables:

- Dependency manifests and lockfiles.
- Dependabot/OSV/Dependency-Check or equivalent scan.
- High/critical issue disposition.
- CycloneDX or SPDX SBOM for public/field releases.
- OpenSSF Scorecard for public repositories.

Resources: [R8: NIST SP 800-218: Secure Software Development Framework \(SSDF\)](#); [R19: GitHub: About Dependabot alerts](#); [R21: OSV-Scanner](#); [R22: OWASP Dependency-Check](#); [R23: OWASP CycloneDX Bill of Materials Standard](#); [R24: OpenSSF Scorecard](#); [R25: SLSA: Supply-chain Levels for Software Artifacts](#)

Templates: T19 CI Security Scan Workflow; T20 Dependabot Config

A11. Audit Logging and Monitoring

Use when: Use when users authenticate, commands are issued, firmware is updated, devices are provisioned, or sensitive data is accessed.

Deliverables:

- Security event list.
- Safe log format with no secrets.
- Retention period.
- Alert path for high-risk events.

Resources: [R4: OWASP Cheat Sheet Series](#); [R6: NISTIR 8259A: IoT Device Cybersecurity Capability Core Baseline](#); [R9: NIST Cybersecurity Framework 2.0](#)

Templates: T13 Incident Response Plan

A12. Incident Response and Vulnerability Disclosure

Use when: Use for every internet-connected project; mandatory for public projects.

Deliverables:

- Incident response procedure.
- Token/device revocation path.
- Vulnerability reporting instructions.
- Supported versions and expected response timeline.

Resources: [R12: CISA Vulnerability Disclosure Policy Template](#); [R13: CISA Known Exploited Vulnerabilities Catalog](#); [R14: CERT Guide to Coordinated Vulnerability Disclosure](#); [R17: GitHub: Adding a security policy to your repository](#)

Templates: T13 Incident Response Plan; T15 SECURITY.md

A13. Open-Source Release and Web Conversion

Use when: Use when publishing code, CAD, PCB files, firmware, docs, datasets, demos, or a future web version of this checklist.

Deliverables:

- Repo scrubbed for secrets and private data.
- Secure setup instructions included.
- Unsafe defaults clearly avoided.
- SECURITY.md, license, SBOM, and release notes included.
- Checklist headings and anchors preserved for web conversion.

Resources: [R11: CISA Secure by Design](#); [R17: GitHub: Adding a security policy to your repository](#); [R18: GitHub: Secret scanning push protection](#); [R23: OWASP CycloneDX Bill of Materials Standard](#); [R24: OpenSSF Scorecard](#)

Templates: T15 SECURITY.md; T16 Release Signoff

Minimum repository structure

```
README.md
SECURITY.md
docs/threat-model.md
docs/network-diagram.png or .drawio
docs/data-inventory.md
docs/deployment-hardening.md
docs/incident-response.md
.env.example
.gitignore
.github/dependabot.yml
.github/workflows/security-baseline.yml
firmware/versioning-notes.md
release/sbom.cdx.json
```

Template appendix

The companion template pack contains these templates as standalone files. They are also included below for easy copying.

T1 Audit Record

```
# Application Security Audit Record

Project name:
Repository / location:
Hardware platform:
Firmware/software stack:
Connectivity type: Wi-Fi / Ethernet / Cellular / BLE gateway / LoRaWAN / Other
Cloud/broker/API services:
Student security owner:
Faculty/PI reviewer:
Risk level: Low / Medium / High
Review gate: Design / Pre-network / Pre-demo or release / Post-change
Date:
Decision: Approved / Approved with conditions / Not approved
Conditions or required add-ons:
Reviewer notes:
```

T2 Threat Model

```
# Threat Model

## System summary

## Data-flow diagram link or image

## Trust boundaries
1. Device boundary:
2. Network boundary:
```

```

3. Cloud/API boundary:
4. Human/admin boundary:

## Assets
- Credentials:
- Firmware/source:
- Sensor/data outputs:
- Actuators/safety-relevant functions:
- Cloud accounts/services:
- Logs:

## Likely attackers / misuse cases
- Curious student or visitor:
- Internet scanner/bot:
- Malicious user with account:
- Stolen or physically accessed device:
- Compromised developer laptop:
- Malicious dependency or supply-chain compromise:

## Top threats and mitigations
| Threat | Impact | Likelihood | Mitigation | Residual risk | Owner |
|---|---|---|---|---|---|
| | | | | | |
| | | | | | |

## Faculty/PI review
Residual risk accepted? Yes / No
Reviewer:
Date:

```

T3 Data Flow

```

# Data-Flow Diagram Checklist

Include these elements in the diagram:
- Device MCU/SBC
- Sensors
- Actuators
- Power/control electronics
- Firmware modules
- Mobile/web dashboard
- Cloud service/API/broker
- Database/storage/logging
- User/admin identities
- External libraries/services
- Trust boundaries
- Data types flowing over each link
- Protocols and ports
- Where credentials are stored and transmitted

```

T4 Asset Inventory

```

# Asset Inventory

| Asset | Type | Location | Owner | Sensitivity | Protection | Backup/recovery |
|---|---|---|---|---|---|---|
| Firmware source | Software | Repo | | | | |
| Device credential | Secret | Device/cloud | | High | | |
| Sensor data | Data | | | | | |
| Command API | Interface | | | | | |
| Logs | Data | | | | | |

```

T5 Security Ownership

```

# Security Ownership

Student security owner:
Backup owner:
Faculty/PI reviewer:
University IT/security contact, if applicable:
Cloud account owner:
Hardware safety owner:

Responsibilities:
- Maintains threat model and checklist evidence.
- Reviews secrets before commits/releases.
- Confirms pre-network gate before connecting hardware.

```

- Coordinates incident response.
- Ensures documentation is updated after design changes.

T6 Risk Classification

Risk Classification

Risk level: Low / Medium / High

Low-risk indicators:

- Local-only or outbound-only data display.
- No remote commands.
- No personal/sensitive data.
- No public internet exposure.

Medium-risk indicators:

- Cloud logging.
- Web dashboard or API.
- MQTT/HTTP/WebSocket connectivity.
- Remote configuration.
- Public repository.

High-risk indicators:

- Remote actuation or safety impact.
- Human-subject, image/audio, location, biometric, health, student, or other identifiable data.
- Public endpoint or inbound service.
- OTA updates.
- Credentials stored on device.
- Field deployment outside lab.

Decision rationale:

Required add-ons:

Faculty/PI sign-off:

T7 Network Exposure Review

Network Exposure Review

Device name / ID:

Network used:

Expected outbound destinations and ports:

Expected inbound ports, if any:

Public internet reachable? Yes / No

Router port forwarding? Yes / No

Firewall rules reviewed? Yes / No

Discovery protocols enabled: mDNS / UPnP / BLE / Wi-Fi AP / Other

Scan command used:

Scan result summary:

Unexpected services found:

Remediation completed:

Reviewer/date:

T8 Device Registry

Device Registry

Device ID	Hardware revision	Firmware version	Credential ID / cert fingerprint	Owner	Location	Risk level
Revocation tested?						
--- --- --- --- --- --- ---						

Revocation procedure:

1. Disable token/certificate in broker/cloud/API.
2. Confirm device cannot connect.
3. Provision replacement credential.
4. Record reason and date.

T9 Secrets Inventory

Secrets Inventory

Do not commit this file to a public repository. Store securely.

Secret	Purpose	Location	Owner	Rotation method	Last rotated	Exposure response
--- --- --- --- --- ---						

```
| Device API token | | | | | |
| MQTT credential | | | | | |
| TLS private key | | | | | |
| Cloud token | | | | | |
```

Leaked secret response:

1. Revoke/disable.
2. Rotate.
3. Search logs/repo history for use.
4. Verify replacement.
5. Document incident.

T10 Command Register

Command Register and Safety Review

```
| Command | Who/what may issue it | Preconditions | Safety limits | Interlock | Logged fields | Failure behavior |
|---|---|---|---|---|---|---|
| | | | | | |
```

Required tests:

- Unauthorized user blocked.
- Wrong device ID blocked.
- Out-of-range command blocked.
- Replay/malformed command blocked or harmless.
- Command log created.
- Device enters safe state on connection loss or command failure.

T11 Firmware Release Record

Firmware Release Record

```
Device / board:
Firmware version:
Source commit hash:
Build date:
Toolchain and version:
Dependency/SDK versions:
Build machine or CI job:
Secure boot enabled? Yes / No / N/A
Flash/storage encryption enabled? Yes / No / N/A
Firmware signed? Yes / No / N/A
Signing key owner/location:
Rollback/recovery tested? Yes / No
Known issues:
Release approver/date:
```

T12 Data Inventory

Data Inventory and Privacy Review

```
| Data type | Source | Contains personal/sensitive data? | Stored where? | Transmitted where? | Retention period |
Protection |
|---|---|---|---|---|---|
| Sensor readings | | | | | |
| Images/audio/video | | | | | |
| Location | | | | | |
| Logs | | | | | |
```

```
Data minimization decisions:
Human-subject/privacy review needed? Yes / No
Demo/public release scrub plan:
```

T13 Incident Response Plan

Incident Response Plan

Triggers:

- Leaked secret.
- Unexpected public exposure.
- Unauthorized command.
- Device stolen or lost.
- Known exploited vulnerability in dependency.
- Suspicious logs or repeated failed access.

Response steps:

1. Make device/system safe.

2. Disable affected endpoint/device/token/account.
3. Preserve relevant logs and evidence.
4. Notify student security owner and faculty/PI.
5. Notify university IT/security or collaborator if required.
6. Rotate credentials and patch.
7. Verify remediation.
8. Document after-action notes and checklist updates.

Contacts:

- Student owner:
- Faculty/PI:
- IT/security:
- Cloud/broker admin:

T14 .gitignore Starter

```
# Local secrets and generated files
.env
.env.*
!.env.example
*.key
*.pem
*.p12
*.pfx
*.crt
*.csr
secrets.*
credentials.*
config.local.*

# Python
__pycache__/.
.venv/
venv/
*.pyc

# Node
node_modules/

# Firmware/build artifacts
.pio/
build/
dist/
*.bin
*.elf
*.map

# OS/editor
.DS_Store
.vscode/settings.json
```

T15 SECURITY.md

Security Policy

Supported versions

Version / branch	Supported?
main	Yes / No
latest release	Yes / No

Reporting a vulnerability

Please do not open a public issue for suspected vulnerabilities. Report security concerns to:

- Email:
- GitHub private vulnerability reporting, if enabled:

Please include:

- Affected hardware/software version.
- Description of the issue.
- Steps to reproduce, if safe.
- Potential impact.
- Suggested mitigation, if known.

Scope

In scope:

- Firmware in this repository.
- Web/API/dashboard code in this repository.
- Deployment examples provided by this project.

Out of scope:

- Third-party services not controlled by the project.
- Denial-of-service testing against university or public infrastructure.
- Physical attacks that create safety risk without prior permission.

Response expectations

We will acknowledge good-faith reports as promptly as feasible and coordinate remediation and disclosure.

T16 Release Signoff

Pre-Connection / Pre-Release Signoff

Project:

Review gate: Pre-network / Pre-demo / Public release / Field deployment

Risk level:

Required evidence:

- Threat model complete: Yes / No
- Secrets scan complete: Yes / No
- Dependency scan complete: Yes / No
- Network scan complete: Yes / No
- TLS/certificate validation checked: Yes / No
- Authentication/authorization tested: Yes / No / N/A
- Remote commands/safety interlocks tested: Yes / No / N/A
- Firmware update/recovery tested: Yes / No / N/A
- Data/privacy review complete: Yes / No / N/A
- SECURITY.md included for public release: Yes / No / N/A

Open issues:

Decision:

Conditions:

Student security owner/date:

Faculty/PI reviewer/date:

T17 .env.example

Example only. Do not put real secrets in this file.

```
DEVICE_ID=example-device-001
MQTT_HOST=example-broker.example.edu
MQTT_PORT=8883
MQTT_USERNAME=example-device-user
MQTT_PASSWORD=replace-with-provisioned-secret
API_BASE_URL=https://example-api.example.edu
LOG_LEVEL=INFO
TLS_CA_CERT_PATH=./certs/ca.example.pem
CLIENT_CERT_PATH=./certs/device.example.crt
CLIENT_KEY_PATH=./certs/device.example.key
```

T18 API Endpoint Inventory

API Endpoint Inventory

Method	Path/topic	Purpose	Auth required?	Required role/scope	Input validation	Rate limit	Logs?
GET	/api/devices/{id}/status		Yes	viewer	device ID authorization		Yes
POST	/api/devices/{id}/command		Yes	operator/admin	schema + range checks		Yes

T19 CI Security Scan Workflow

name: security-baseline

on:

pull_request:

push:

branches: [main]

schedule:

- cron: '0 8 * * 1'

```

permissions:
  contents: read

jobs:
  osv-scanner:
    name: OSV dependency and source scan
    runs-on: ubuntu-latest
    steps:
      - uses: actions/checkout@v4
      - name: Run OSV-Scanner
        uses: google/osv-scanner-action/osv-scanner-action@v2
        with:
          scan-args: |
            --recursive
            .

  scorecard:
    name: OpenSSF Scorecard
    runs-on: ubuntu-latest
    permissions:
      contents: read
      security-events: write
      id-token: write
    steps:
      - uses: actions/checkout@v4
      - name: Run OpenSSF Scorecard
        uses: ossf/scorecard-action@v2.4.0
        with:
          results_file: results.sarif
          results_format: sarif
      - name: Upload Scorecard SARIF
        uses: github/codeql-action/upload-sarif@v3
        with:
          sarif_file: results.sarif

# Optional for code repositories:
# - Add CodeQL for supported languages.
# - Enable GitHub Dependabot alerts and secret scanning/push protection in repository settings.
# - Pin third-party GitHub Actions by full commit SHA for higher assurance.

```

T20 Dependabot Config

```

version: 2
updates:
  - package-ecosystem: "github-actions"
    directory: "/"
    schedule:
      interval: "weekly"

  - package-ecosystem: "pip"
    directory: "/"
    schedule:
      interval: "weekly"

  - package-ecosystem: "npm"
    directory: "/"
    schedule:
      interval: "weekly"

```

T21 MQTT ACL Example

```

# Example only. Broker syntax varies.
# Principle: each device can publish telemetry for itself and subscribe only to commands for itself.

user device-001
topic write devices/device-001/telemetry/#
topic read devices/device-001/commands/#
topic read devices/device-001/config/#

user dashboard-viewer
topic read devices/+/telemetry/#

user operator
topic read devices/+/telemetry/#
topic write devices/+/commands/#

```

Reference list

- R1. [OWASP Internet of Things Security Verification Standard \(ISVS\)](#)
- R2. [OWASP Internet of Things Security Testing Guide \(ISTG\)](#)
- R3. [OWASP Application Security Verification Standard \(ASVS\)](#)
- R4. [OWASP Cheat Sheet Series](#)
- R5. [NIST SP 800-213: IoT Device Cybersecurity Guidance](#)
- R6. [NISTIR 8259A: IoT Device Cybersecurity Capability Core Baseline](#)
- R7. [NISTIR 8259B: IoT Non-Technical Supporting Capability Core Baseline](#)
- R8. [NIST SP 800-218: Secure Software Development Framework \(SSDF\) Version 1.1](#)
- R9. [NIST Cybersecurity Framework 2.0](#)
- R10. [NIST Privacy Framework](#)
- R11. [CISA Secure by Design](#)
- R12. [CISA Vulnerability Disclosure Policy Template](#)
- R13. [CISA Known Exploited Vulnerabilities Catalog](#)
- R14. [CERT Guide to Coordinated Vulnerability Disclosure](#)
- R15. [OWASP Threat Dragon](#)
- R16. [OWASP Zed Attack Proxy \(ZAP\)](#)
- R17. [GitHub: Adding a security policy to your repository](#)
- R18. [GitHub: Secret scanning push protection](#)
- R19. [GitHub: Dependabot alerts](#)
- R20. [GitHub: Code scanning with CodeQL](#)
- R21. [OSV-Scanner](#)
- R22. [OWASP Dependency-Check](#)
- R23. [OWASP CycloneDX Bill of Materials Standard](#)
- R24. [OpenSSF Scorecard](#)
- R25. [SLSA: Supply-chain Levels for Software Artifacts](#)
- R26. [Mozilla SSL Configuration Generator](#)
- R27. [OASIS MQTT Version 5.0 Specification](#)
- R28. [Espressif ESP-IDF Secure Boot documentation](#)
- R29. [Espressif ESP-IDF Flash Encryption documentation](#)
- R30. [OWASP Software Assurance Maturity Model \(SAMM\)](#)
- R31. [OWASP Top Ten Web Application Security Risks](#)
- R32. [OWASP API Security Project / API Security Top 10](#)
- R33. [OWASP Web Security Testing Guide stable version](#)
- R34. [OWASP Software Component Verification Standard \(SCVS\)](#)
- R35. [CISA 2025 Minimum Elements for a Software Bill of Materials \(SBOM\)](#)
- R36. [CISA Software Bill of Materials for AI - Minimum Elements](#)
- R37. [NIST SP 800-218 Rev. 1 / SSDF Version 1.2 Initial Public Draft](#)
- R38. [GitHub Docs: Creating a new repository](#)
- R39. [GitHub Docs: Uploading a project to GitHub](#)
- R40. [GitHub Docs: Configuring a publishing source for GitHub Pages](#)
- R41. [Creative Commons Attribution 4.0 International](#)

GitHub repository packaging and publication guide

Recommended repository name: `open-hardware-appsec-checklist`.

Recommended owner: `nanosystemslab`.

Recommended short description: Application security audit checklist and templates for open hardware projects with internet connectivity.

Recommended visibility: public, if this is intended as a reusable lab/community resource. Use private only if you add institutional internal contacts, unpublished research details, or examples containing sensitive information.

Recommended repository structure

```
open-hardware-appsec-checklist/
├── README.md
├── CHECKLIST.md
├── LICENSE.md
├── SECURITY.md
├── CONTRIBUTING.md
├── CITATION.cff
├── .gitignore
├── .env.example
├── .nojekyll
├── docs/
│   ├── index.md
│   ├── GITHUB_UPLOAD_GUIDE.md
│   ├── REFERENCE_SOURCES.md
│   └── FUTURE_UPDATE_PROMPT.md
├── templates/
│   ├── audit-record.md
│   ├── threat-model.md
│   ├── data-flow-checklist.md
│   ├── asset-inventory.md
│   ├── risk-classification.md
│   ├── security-ownership.md
│   ├── network-exposure-review.md
│   ├── api-endpoint-inventory.md
│   ├── command-register.md
│   ├── device-registry.md
│   ├── secrets-inventory.md
│   ├── data-inventory.md
│   ├── firmware-release-record.md
│   ├── incident-response.md
│   ├── release-signoff.md
│   └── mqtt-acl-example.conf
├── .github/
│   ├── dependabot.yml
│   └── workflows/
│       └── security-baseline.yml
```

Open Hardware Application Security Audit Checklist by Nanosystems Lab, University of Hawai'i at Mānoa, licensed under CC BY 4.0.

Before public release, replace these placeholders

- Security contact email in `SECURITY.md`.
- Preferred maintainer/contact in `README.md`.
- Citation author details in `CITATION.cff`.
- Any University of Hawai'i or Nanosystems Lab branding language that should be institutionally reviewed.
- Any internal URLs, IP ranges, private emails, sponsor details, or unpublished project examples.

Future update prompt

Use this prompt in a future ChatGPT session when you want to refresh the checklist and repository:

Please update my Open Hardware Application Security Audit Checklist repository and downloadable files. Use the current date and review current official guidance from OWASP, NIST, CISA, GitHub, OpenSSF, OASIS MQTT, CycloneDX, SPDX, OSV, and relevant firmware/security documentation. Compare the current sources against the previous repository files, identify material changes, update the checklist, reference document, Markdown web version, template pack, GitHub README, SECURITY.md, GitHub Actions/Dependabot examples, source list, and future-update notes. Treat final published standards as requirements and draft/public-comment documents as watch items unless they have become final. Preserve the practical student-lab workflow, stop-sign questions, risk classification, add-on catalog, and template structure. Produce updated downloadable DOCX, Markdown, template ZIP, and GitHub-ready repository ZIP files, and summarize the most important source changes with citations.

Web-conversion notes

This document was structured with stable headings, short sections, and template blocks so it can be converted to a web page. Suggested future web features include collapsible add-ons, status filters, a downloadable template pack, and per-project audit-record export.